

Access Control Policy

ISMS Governance Policy | Version 1.0 | Approved

Document Owner	Information Security / GRC
Status	Approved 2026-09-23
Review Frequency	At least annually and upon significant change
Framework Alignment	ISO/IEC 27001:2022
Classification	Internal Use

1. Purpose

Define requirements for controlling logical access to Axiom AI information and technology resources.

2. Scope

Applies to user accounts, privileged accounts, service accounts, applications, cloud resources, databases, repositories, SaaS platforms, and other systems within the ISMS scope.

3. Access Requirements

- Access is granted based on business need, job responsibilities, and least privilege.
- Unique identities shall be used where technically feasible.
- MFA shall be implemented based on risk and system capability, with priority for privileged and externally accessible access.
- Privileged access shall be restricted, monitored, and periodically reviewed.
- Access shall be reviewed after role changes and departures.
- Shared accounts shall be avoided unless necessary and controlled.

4. Account Lifecycle

- New access requires appropriate authorization.
- Access shall be modified promptly after role changes.
- Access shall be revoked promptly after termination or when business need ends.
- Service accounts shall have defined ownership and protected credentials.

5. Monitoring and Review

Authentication events, privileged activity, and relevant access activity shall be logged where supported. Access reviews shall be documented and exceptions tracked.

6. Exceptions

Exceptions require documented justification, risk assessment, approval, and a review or expiration date.

7. Review and Approval

This policy shall be reviewed at least annually and when significant changes occur to Axiom AI's business, technology, threats, legal or contractual obligations, or information security risk profile.

8. Portfolio Disclaimer

Axiom AI Technologies is a fictional organization created for portfolio demonstration purposes. This policy is inspired by and based on real professional cybersecurity, GRC, and ISO/IEC 27001 practices and is not an actual organizational policy.